代码安全审计报告

敏感信息泄露风险检测与修复建议

扫描来源	演示项目
扫描时间	2026-10-17 14:42
文件数量	2
代码行数	15
安全评分	82 / 100

一 风险概览

等级	严重	高	中	低	合计
数量	0	0	4	2	6

风险等级由规则信号、代码上下文、文件类型和疑似凭据特征综合计算。检测结果需要人工确认，不能替代正式安全评估。

二 检测结果

1. 中风险 API Key app.py:3

风险说明：命中 API 密钥赋值 特征，结合上下文得到风险分 53/100。

代码行：[API Key已脱敏:sk_**********890]"

修复建议：将密钥移出源码，放入环境变量或密钥管理服务，并在部署时注入。提交代码前同步清理历史提交中的旧密钥。

示例：

```
api_key = os.environ["SERVICE_API_KEY"]
```

2. 中风险 数据库账号密码 app.py:4

风险说明：命中 数据库凭据 特征，结合上下文得到风险分 67/100。

代码行：[数据库账号密码已脱敏:dem********026]

修复建议：把数据库密码放进环境变量或密钥服务，连接串中不要嵌入真实密码。为不同环境使用独立账号，并限制账号权限。

示例：

```
db_password = os.getenv("DATABASE_PASSWORD")
url = f"postgresql://app_user:{db_password}@db.example/app"
```

3. 中风险 JWT Token app.py:5

风险说明：命中 JWT 令牌 特征，结合上下文得到风险分 51/100。

代码行：JWT_TOKEN = "[JWT Token已脱敏:eyJ**********ure]"

修复建议：不要把 JWT 写入源码、日志或截图。使用短时效令牌，并通过安全的运行时配置或登录流程获取。

示例：

```
token = request.headers.get("Authorization")
if token and token.startswith("Bearer "):
```

```
token = token[7:]
```

4. 低风险 邮箱 app.py:6

风险说明：命中 邮箱地址 特征，结合上下文得到风险分 8/100。

代码行：CONTACT_EMAIL = "[邮箱已脱敏:stu**********com]"

修复建议：确认邮箱是否属于业务必须信息。公开代码中使用示例地址或脱敏数据，避免将真实个人信息提交到仓库。

示例：
```
contact_email = "student@example.com" # 示例数据
```

5. 低风险 手机号 app.py:7

风险说明：命中 手机号 特征，结合上下文得到风险分 39/100。

代码行：CONTACT_PHONE = "[手机号已脱敏:138****000]"

修复建议：测试代码使用虚构号码或哈希后的测试标识，真实手机号应放在受控数据源中，并限制访问和导出。

示例：
```
phone = os.getenv("TEST_PHONE", "13800000000") # 仅用于本地演示
```

6. 中风险 数据库账号密码 app.py:10

风险说明：命中 数据库凭据 特征，结合上下文得到风险分 67/100。

代码行： return f"[数据库账号密码已脱敏:pos**********D}@]localhost/demo"

修复建议：把数据库密码放进环境变量或密钥服务，连接串中不要嵌入真实密码。为不同环境使用独立账号，并限制账号权限。

示例：
```
db_password = os.getenv("DATABASE_PASSWORD")
url = f"postgresql://app_user:{db_password}@db.example/app"
```

三 整改记录

系统支持将问题标记为已确认、误报、已修复或忽略本次。正式提交报告前，请由项目成员完成人工复核，并在源代码仓库中完成密钥轮换。

编号	文件与行号	风险类型	当前状态
F-0001	app.py:3	API Key	待确认
F-0002	app.py:4	数据库账号密码	待确认
F-0003	app.py:5	JWT Token	待确认
F-0004	app.py:6	邮箱	待确认
F-0005	app.py:7	手机号	待确认
F-0006	app.py:10	数据库账号密码	待确认

四 使用说明

本报告由 CodeGuard 代码敏感信息审计平台生成。平台只提供风险发现和教育性修复建议，不会自动修改用户源代码。建议将本报告与代码整改记录一并归档。